

SBOM Enrichment Summary & Next Steps

Files Changed

metadata-enricher.mjs ? Core enrichment logic with hardened fallbacks and dependency cleaning.
tools/run_metadata_enricher.mjs ? Runner script to load SBOM, run enrichment, and write output.
tools/diff_enrichment.mjs ? Diff reporter that compares pre/post enrichment metadata changes.

Key Changes in Behavior

Hardened Fallbacks

getFallbackMetadata(...) now injects CycloneDX-safe defaults:

```
licenses: [{ license: { id: "NOASSERTION", name: "License Not Specified" } }]  
supplier: { name: "NOASSERTION" }  
author: "NOASSERTION"  
version: "0.0.0"  
copyright: "NOASSERTION"
```

Always-Apply Sanitizer

ensureFallbacks(component, validRefs) now ensures:

- Non-empty, normalized licenses
- Supplier object with a populated name
- Author string
- Copyright stanza
- Version value
- Valid dependsOn references only

Dependency Cleaning

Valid references map built during enrichSbom. Invalid dependsOn entries are removed and logged.

Behavior Before vs After

Before

- Web lookups attempted, but missing fields remained untouched
- SBOM validation could fail due to missing metadata
- Invalid dependsOn references caused errors

After

- Web lookups still attempted, but safe defaults injected when data is missing
- SBOM becomes validator-safe with fallback metadata
- Invalid dependsOn references removed; dependency graph cleaned

Run Results

- Enrichment complete ? stage_10_auto-enrich.cdx.json written
- Diff report ? 3 components updated with fallback metadata

Commands You Can Run

```
git status  
git diff metadata-enricher.mjs
```

```
node tools/run_metadata_enricher.mjs
node tools/diff_enrichment.mjs
cyclonedx validate --input stage_10_auto-enrich.cdx.json
```

Next Suggested Steps

Resume pipeline now

```
node products/factory-views/00-scripts/sbom/sbom.script.mjs --resume
```

Run CycloneDX validation first

Confirm schema compliance before resuming.

Produce NOASSERTION audit report

List components using fallback metadata for review.